

user to “http://www.maliciouswebsite.com” instead of displaying the message.

The second kind of XSS attack is a Reflected XSS Attack. Here the value isn’t stored, but it “reflected” by the target server. To clarify, what reflected here means is that the attack code while being provided by the user is not being processed properly and is somehow ending up on the page.

If there is any way for you to specify a parameter to an webpage via the URL such that the supplied parameter gets injected or “written” to the page directly without being processed, then you have yourself a good old Reflected XSS Attack.

Since the parameter you specify is being written to the page somewhere, you can know that you will be able to run any arbitrary code by providing it as a parameter in the URL. Additionally since the code will appear to be from the trusted site itself, the browser will not be able to block it either.

A hacker could craft a URL which includes the code he wishes to run on the user-end, and distribute this URL through forums / email / comments

Always a good practice to validate all input on the server side. XSS can occur when untrusted user input is used in an HTTP response. In a reflected XSS attack, an attacker crafts a URL with the attack script and post it to another website, email it, or otherwise get him to click on it.

oops! You entered 1111 instead of your three digit code. Please try again.

Shopping Cart			
Shopping Cart Items -- To Buy Now	Price	Quantity	Total
Studio RTA - Laptop/Reading Cart with Tiling Surface - Cherry	69.99	1	\$69.99
Dynex - Traditional Notebook Case	27.99	1	\$27.99
Hewlett-Packard - Pavilion Notebook with Intel Centrino	1599.99	1	\$1599.99
3 - Year Performance Service Plan \$1000 and Over	299.99	1	\$299.99

The total charged to your credit card: \$1997.96

Enter your credit card number:

Enter your three digit access code:

On clicking this message in the message list, the browser will execute the JavaScript code we entered earlier

oops! You entered injected html instead of your three digit code. Please try again.

Shopping Cart			
Shopping Cart Items -- To Buy Now	Price	Quantity	Total
Studio RTA - Laptop/Reading Cart with Tiling Surface - Cherry	69.99	1	\$69.99
Dynex - Traditional Notebook Case	27.99	1	\$27.99
Hewlett-Packard - Pavilion Notebook with Intel Centrino	1599.99	1	\$1599.99
3 - Year Performance Service Plan \$1000 and Over	299.99	1	\$299.99

The total charged to your credit card: \$1997.96

Enter your credit card number:

Enter your three digit access code:

In this example we have just displayed a popup, but we could as easily add code to steal session information, or as we can see in the following example, to redirect the user to a malicious website.